

Federal Election Online Searchable Electronic Rulemaking System (FOSERS)

Introduction

This document defines contract requirement for – Federal Election Online Searchable Electronic Rulemaking System – FOSERS Application.

The requirement includes maintaining, upgrading, migrating, or re-architect/re-programing the application, based on the requests from legislation divisions, and/or from security mandates.

Application Overview

Federal Election Online Searchable Electronic Rulemaking System, also called FOSERS. It is used by Office of General Counsel (OGC) – Policy Division.

FOSERS is the online search system where the documents or metadata can be text searched (dates from LM Pro to FRAPS, document types as recognized by the assignment in FRAPS by the User staff), etc.

FOSERS is a search application available on the FEC’s website, which allows both internal and external users to conduct text and data searches of the FEC’s rulemaking documents. It pulls data from the Law Manager database and documents from a repository on the FEC’s network.

This application is time sensitive and mission critical. This is because FOSERS is a key point of entry to the public record of the Commission’s regulatory process, enabling the agency to provide the transparency required by law. Therefore, failure of FRAPS can result in failure of the agency’s ability to provide guidance to the public.

user interface is:

<https://sers.fec.gov/fosers/>

Maintenance Specifications

As legislative, reporting forms, or other requirements can change, the FEC often makes unscheduled requests for data, data subsets, files from backup, changes, or enhancements to these systems. These requests are typically made on a “need it now” basis and may be critical. The requester must demonstrate that they have the resources and the flexibility to manage and perform these types of requests without impacting the application and system maintenance or other initiatives. These requests shall be included as part of normal maintenance efforts.

Architecture

Application is located on Amazon Cloud

Attachment 1A - FEC Searchable Legal Systems

Contracting Requirements

FRAPS is a three-tier application by design.

- Database tier:
 - Current Amazon RDS (Oracle 11g)
 - Will migrate to Amazon Aurora PostgreSQL (with Enterprise License)
 - Schema(s): FRAPS_APPUSER
- Application tier:
 - Java J2EE
- Web tier:
 - Java on Apache Tomcat

Application Server EC2 on Linux OS, running under load balancer.

FRAPS push info to public FOSERS.

The application does not utilize file system storage.

Software

The application utilize below technologies/software:

- Java, running on Tomcat
- J2EE
- Oracle
- PostgreSQL
- Jenkins, CI/CD

Development and Deployment Approach

Application may be required

- to fix bugs and errors discovered by business users or by automated tools, such as security scans,
- to add/modify features from existing features that requested by business users,
- to update the software to remain compatible with evolving environments, such as new OS versions, or third-party APIs,
- to optimize the performance to improve the speed and efficiency of the application to enhance user experience.

In any above cases, Contractor should meet below requirements:

- Best practice with SDLC and Agility.
- Issue Tracking:
 - Use Jira and GitHub to track Issues.
 - In each ticket, define severity, priority, and record resolution.

Attachment 1A - FEC Searchable Legal Systems

Contracting Requirements

- Code Quality
 - Code must adhere to coding standards (e.g., Clean Code, PEP 8) and a minimum code coverage 80% percentage for automated tests.
 - Code must pass functional tested by contractors on development environments.
- Code Deploy and pass Security Scan
 - CI/CD (currently in Jenkins) used for code compiling and pass SAST with zero critical security findings.
- Integration Test and UAT
 - Must conduct Integration test with fec public rulemaking and commenting website.
 - Must conduct User Acceptance Test.
- Change Management: any production changes must
 - have UAT certified
 - Request RFC, along with deployment items, servers, impacts, deployment procedure, backup plan.
 - RFC approved by CAB.
 - In case of emergency fix and deployment, issue and deployment can be documented later than RFC emergency approve, but document must not omit.
- Documentation:
 - Maintaining up-to-date documentation, including user manuals and technical documentation, for long-term support.
 - Link maintenance requirements to original functional specs to understand the impact of changes as Traceability.
 - Treat the maintenance specification as a living document that is updated alongside the software.
 - All documents must be accessible by FEC COR and FEC Deputy CIO of Enterprise Architecture
- Version Control:
 - Application source code, sql statements, and any other scripts must use branching strategy to manage hotfixes and new releases.

Availability and Service Level Agreement (SLA)

- Availability
 - Application is running daily.
 - Patch or other maintenance should be scheduled over weekend.
- SLA
 - Critical bugs or Urgent issues must be acknowledged within 2 hours and assign resource to fix it or find temporary workaround within 12 hours.

Attachment 1A - FEC Searchable Legal Systems
Contracting Requirements

- **Recoverability**
 - Apart from monthly security patch over the weekend, the Maximum Tolerable Downtime (MTD) is 12 hours and Recovery Point Objectives (RPO) is 12 hours.

Compliance & Data Sovereignty

- FEC is following the principles/standards for SOC1, SOC2, SOC3, ISO 27001, ISO 27017, ISO 27018, ISO 9001, PCI, FedRAMP.
Guidance from our legal counsel: HIPAA does not apply to the FEC, since we are not a healthcare provider; however, the Rehabilitation Act and Title VII do apply to us and require federal agencies to protect the confidentiality of medical information.
- Data Classification is Public
- No end-to-end data encryption is required.

Application Security

- The protocol uses HTTPS to access the workload
- Through application, the file (from local or shared folder) is uploaded to server in blobs, blobs are converted into PDF and store in database
- User authentication is required to access FRAPS application

Monitoring

- **The application has monitoring solution in AWS.**
- **Automatic alerts for Application availability also sent via email.**

Backup and Restore

Production databases and application have daily snapshot and keep the snapshot for past 7 days.

Environment and Shared Responsibilities

- All servers (Development, Test, Production) should be built by FEC System Administrator.
- All servers (Development, Test, Production) should be patched by FEC System Administrator.
- Test Environment Require a dedicated staging environment that mirrors production for validating fixes.
- Contractors have privileges to push code into development servers.

Attachment 1A - FEC Searchable Legal Systems

Contracting Requirements

- Upon completion of development, test in development servers, contractors must provide detailed instructions to DBA or System Administrator for Test or Production Deployment.

Technical Support

The Channels for reporting maintenance issues is, in general, go through FEC help desk or via automated monitoring alerts, however, it should not prevent receiving reports directly from FEC internal business users.

Federal Election Online Rulemaking Comment Entry System (FORCES)

Introduction

This document defines contract requirement for – Federal Election Online Rulemaking Comment Entry System – FORCES Application.

The requirement includes maintaining, upgrading, migrating, or re-architect/re-programing the application, based on the requests from legislation divisions, and/or from security mandates.

Application Overview

Federal Election Online Rulemaking Comment Entry System, also called FORCES. It is used by Office of General Counsel (OGC) – Policy Division.

FORCES is an online comment entry system, through which members of the public can submit comments on Commission rulemakings. These comments are then screened by Policy staff and published through the FRAPS application.

FORCES provides online access for the public to:

- Enter comments
- Stores comments for later review by FEC Policy Staff.

After Publishing, there may be times when the external community is allowed to comment. The FEC staff reviews the comment and the associated commenter information. FORCES then presents the FEC staff member with a view of potential duplicate players from LM Pro. If the FEC staff determines the commenter is a new player, he/she then selects it as a new entry/new player. This new player record is saved to LM Pro, inclusive of player's name, address, phone number, the comment, and the date the comment was received. If the FEC Staff determines that the commenter is an existing entity based on the possible duplicates presented, he/she then selects the matching entry/ existing player from the list. FORCES updates this data and attributes the comment to the player, associates the comment to the specific regulation number and captures the date comment was received, and any player demographics updates.

Likewise, entry into LM Pro, via a Calendar Event or a Note Field, can create an option in the FORCES screens for external users to select to be witnesses in the event that a hearing is scheduled. This information is also passed to LM Pro and upon FEC staff approval; the player is denoted in LM Pro as a potential witness as well as a commenter in the player tab.

This application is time sensitive and mission critical. FORCES is critical to a core agency function; the Commission is required by the Administrative Procedures Act ("APA") to consider public comments on proposed regulations, and FORCES is the easiest and most commonly used way for the public to participate in this process. Failure of FORCES during an open comment

Attachment 1A - FEC Searchable Legal Systems
Contracting Requirements

period would render the Commission largely unable to comply with the APA(**Administrative Procedure Act**).

user interface is:

[FEC | Legal | Pending rulemaking matters for comment](#)

Maintenance Specifications

As legislative, reporting forms, or other requirements can change, the FEC often makes unscheduled requests for data, data subsets, files from backup, changes, or enhancements to these systems. These requests are typically made on a “need it now” basis and may be critical. The quoter must demonstrate that they have the resources and the flexibility to manage and perform these types of requests without impacting the application and system maintenance or other initiatives. These requests shall be included as part of normal maintenance efforts.

Architecture

Application is located on Amazon Cloud

FORCES is a three-tier application by design.

- Database tier:
 - Current Amazon RDS (Oracle 11g)
 - Will migrate to Amazon Aurora PostgreSQL (with Enterprise License)
 - Schema(s): FRAPS_APPUSER
- Application tier:
 - Java J2EE
- Web tier:
 - Jave on Apache Tomcat

Application Server EC2 on Linux OS, running under load balancer.

FRAPS push info to public FOSERS.

The application does not utilize file system storage.

Software

The application utilize below technologies/software:

- Java, running on Tomcat
- J2EE
- Oracle
- PostgreSQL
- Jenkins, CI/CD

Development and Deployment Approach

Application may be required

- to fix bugs and errors discovered by business users or by automated tools, such as security scans,
- to add/modify features from existing features that requested by business users,
- to update the software to remain compatible with evolving environments, such as new OS versions, or third-party APIs,
- to optimize the performance to improve the speed and efficiency of the application to enhance user experience.

In any above cases, Contractor should meet below requirements:

- Best practice with SDLC and Agility.
- Issue Tracking:
 - Use Jira and GitHub to track Issues.
 - In each ticket, define severity, priority, and record resolution.
- Code Quality
 - Code must adherence to coding standards (e.g., Clean Code, PEP 8) and a minimum code coverage 80% percentage for automated tests.
 - Code must pass functional tested by contractors on development environments.
- Code Deploy and pass Security Scan
 - CI/CD (currently in Jenkins) used for code compiling and pass SAST with zero critical security findings.
- Integration Test and UAT
 - Must conduct Integration test with fec public rulemaking and commenting website.
 - Must conduct User Acceptance Test.
- Change Management: any production changes must
 - have UAT certified
 - Request RFC, along with deployment items, servers, impacts, deployment procedure, backup plan.
 - RFC approved by CAB.
 - In case of emergency fix and deployment, issue and deployment can be documented later than RFC emergency approve, but document must not omit.
- Documentation:
 - Maintaining up-to-date documentation, including user manuals and technical documentation, for long-term support.

Attachment 1A - FEC Searchable Legal Systems

Contracting Requirements

- Link maintenance requirements to original functional specs to understand the impact of changes as Traceability.
- Treat the maintenance specification as a living document that is updated alongside the software.
- All documents must be accessible by FEC COR and FEC Deputy CIO of Enterprise Architecture
- Version Control:
 - Application source code, sql statements, and any other scripts must use branching strategy to manage hotfixes and new releases.

Availability and Service Level Agreement (SLA)

- Availability
 - Application is running daily.
 - Patch or other maintenance should be scheduled over weekend.
- SLA
 - Critical bugs or Urgent issues must be acknowledged within 2 hours and assign resource to fix it or find temporary workaround within 12 hours.
- **Recoverability**
 - Apart from monthly security patch over the weekend, the Maximum Tolerable Downtime (MTD) is 12 hours and Recovery Point Objectives (RPO) is 12 hours.

Compliance & Data Sovereignty

- FEC is following the principles/standards for SOC1, SOC2, SOC3, ISO 27001, ISO 27017, ISO 27018, ISO 9001, PCI, FedRAMP.
Guidance from our legal counsel: HIPAA does not apply to the FEC, since we are not a healthcare provider; however, the Rehabilitation Act and Title VII do apply to us and require federal agencies to protect the confidentiality of medical information.
- Data Classification is Public
- No end-to-end data encryption is required.

Application Security

- The protocol uses HTTPS to access the workload
- Through application, the file (from local or shared folder) is uploaded to server in blobs, blobs are converted into PDF and store in database
- User authentication is required to access FRAPS application

Attachment 1A - FEC Searchable Legal Systems
Contracting Requirements

Monitoring

- **The application has monitoring solution in AWS.**
- **Automatic alerts for Application availability also sent via email.**

Backup and Restore

Production databases and application have daily snapshot and keep the snapshot for past 7 days.

Environment and Shared Responsibilities

- All servers (Development, Test, Production) should be built by FEC System Administrator.
- All servers (Development, Test, Production) should be patched by FEC System Administrator.
- Test Environment Require a dedicated staging environment that mirrors production for validating fixes.
- Contractors have privileges to push code into development servers.
- Upon completion of development, test in development servers, contractors must provide detailed instructions to DBA or System Administrator for Test or Production Deployment.

Technical Support

The Channels for reporting maintenance issues is, in general, go through FEC help desk or via automated monitoring alerts, however, it should not prevent receiving reports directly from FEC internal business users.

Federal Election Rulemaking Administration and Publishing System (FRAPS)

Introduction

This document defines contract requirement for Federal Election Committee's Searchable Legal Systems – FRAPS Application.

The requirement includes maintaining, upgrading, migrating, or re-architect/re-programing the application, based on the requests from legislation divisions, and/or from security mandates.

Application Overview

Federal Election Rulemaking Administration and Publishing System, also called FRAPS. It is used by Office of General Counsel (OGC) – Policy Division.

FRAPS is the publication system that allows Policy staff to publish rulemaking documents to the Commission's website. FRAPS pulls data from the Law Manager database and documents from a repository on the Commission's network; through the FRAPS interface staff can link documents for a given rulemaking to the appropriate data (i.e., date, step in the rulemaking process, and in some cases author), and then publish the documents to the Commission's website. FRAPS is interconnected with the FOSERS application (allowing staff as well as the public to search and view the documents published through FRAPS) and the FORCES application (allowing members of the public to submit written comments on proposed regulations).

This application is time sensitive and mission critical. This is because the information will be published on FEC public SERS website where OGC and Commission staff, as well as external users, can search on rulemaking and comments submission. Therefore, failure of FRAPS can result in failure of the agency's ability to provide guidance to the public.

FRAPS user interface is:

<https://fraps.fec.gov/fraps>

Maintenance Specifications

As legislative, reporting forms, or other requirements can change, the FEC often makes unscheduled requests for data, data subsets, files from backup, changes, or enhancements to these systems. These requests are typically made on a "need it now" basis and may be critical. The quoter must demonstrate that they have the resources and the flexibility to manage and perform these types of requests without impacting the application and system maintenance or other initiatives. These requests shall be included as part of normal maintenance efforts.

Attachment 1A - FEC Searchable Legal Systems
Contracting Requirements

Architecture

Application is located on Amazon Cloud

FRAPS is a three-tier application by design.

- Database tier:
 - Current Amazon RDS (Oracle 11g)
 - Will migrate to Amazon Aurora PostgreSQL (with Enterprise License)
 - Schema(s): FRAPS_APPUSER, LMP_APPUSR
- Application tier:
 - Java J2EE
- Web tier:
 - Jave on Apache Tomcat

Application Server EC2 on Linux OS, running under load balancer.

FRAPS push info to public FOSERS (<https://sers.fec.gov/fosers/>) and pull comments from public FORCES ([FEC | Legal | Pending rulemaking matters for comment](#)).

The application does not utilize file system storage.

Software

The application utilize below technologies/software:

- Java, running on Tomcat
- J2EE
- Oracle
- PostgreSQL
- Jenkins, CI/CD

Development and Deployment Approach

Application may be required

- to fix bugs and errors discovered by business users or by automated tools, such as security scans,
- to add/modify features from existing features that requested by business users,
- to update the software to remain compatible with evolving environments, such as new OS versions, or third-party APIs,
- to optimize the performance to improve the speed and efficiency of the application to enhance user experience.

In any above cases, Contractor should meet below requirements:

- Best practice with SDLC and Agility.

Attachment 1A - FEC Searchable Legal Systems

Contracting Requirements

- Issue Tracking:
 - Use Jira and GitHub to track Issues.
 - In each ticket, define severity, priority, and record resolution.
- Code Quality
 - Code must adhere to coding standards (e.g., Clean Code, PEP 8) and a minimum code coverage 80% percentage for automated tests.
 - Code must pass functional tested by contractors on development environments.
- Code Deploy and pass Security Scan
 - CI/CD (currently in Jenkins) used for code compiling and pass SAST with zero critical security findings.
- Integration Test and UAT
 - Must conduct Integration test with fec public rulemaking and commenting website.
 - Must conduct User Acceptance Test.
- Change Management: any production changes must
 - have UAT certified
 - Request RFC, along with deployment items, servers, impacts, deployment procedure, backup plan.
 - RFC approved by CAB.
 - In case of emergency fix and deployment, issue and deployment can be documented later than RFC emergency approve, but document must not omit.
- Documentation:
 - Maintaining up-to-date documentation, including user manuals and technical documentation, for long-term support.
 - Link maintenance requirements to original functional specs to understand the impact of changes as Traceability.
 - Treat the maintenance specification as a living document that is updated alongside the software.
 - All documents must be accessible by FEC COR and FEC Deputy CIO of Enterprise Architecture
- Version Control:
 - Application source code, sql statements, and any other scripts must use branching strategy to manage hotfixes and new releases.

Availability and Service Level Agreement (SLA)

- Availability
 - Application is running daily.
 - Patch or other maintenance should be scheduled over weekend.

Attachment 1A - FEC Searchable Legal Systems

Contracting Requirements

- **SLA**
 - Critical bugs or Urgent issues must be acknowledged within 2 hours and assign resource to fix it or find temporary workaround within 12 hours.
- **Recoverability**
 - Apart from monthly security patch over the weekend, the Maximum Tolerable Downtime (MTD) is 12 hours and Recovery Point Objectives (RPO) is **12 hours.**

Compliance & Data Sovereignty

- FEC is following the principles/standards for SOC1, SOC2, SOC3, ISO 27001, ISO 27017, ISO 27018, ISO 9001, PCI, FedRAMP.
Guidance from our legal counsel: HIPAA does not apply to the FEC, since we are not a healthcare provider; however, the Rehabilitation Act and Title VII do apply to us and require federal agencies to protect the confidentiality of medical information.
- Data Classification is Public
- No end-to-end data encryption is required.

Application Security

- The protocol uses HTTPS to access the workload
- Through application, the file (from local or shared folder) is uploaded to server in blobs, blobs are converted into PDF and store in database
- User authentication is required to access FRAPS application

Monitoring

- **The application has monitoring solution in AWS.**
- **Automatic alerts for Application availability also sent via email.**

Backup and Restore

Production databases and application have daily snapshot and keep the snapshot for past 7 days.

Environment and Shared Responsibilities

- All servers (Development, Test, Production) should be built by FEC System Administrator.
- All servers (Development, Test, Production) should be patched by FEC System Administrator.

Attachment 1A - FEC Searchable Legal Systems

Contracting Requirements

- Test Environment Require a dedicated staging environment that mirrors production for validating fixes.
- Contractors have privileges to push code into development servers.
- Upon completion of development, test in development servers, contractors must provide detailed instructions to DBA or System Administrator for Test or Production Deployment.

Technical Support

The Channels for reporting maintenance issues is, in general, go through FEC help desk or via automated monitoring alerts, however, it should not prevent receiving reports directly from FEC internal business users.

Advise Opinion (AODES)

Introduction

This document defines contract requirement for Federal Election Committee's Searchable Legal Systems – Advisory Opinion Application.

The requirement includes maintaining, upgrading, migrating, or re-architect/re-programing the application, based on the requests from legislation divisions, and/or from security mandates.

Application Overview

Advisory Opinion, also called AODES (Advisory Opinion Data Entry System). It is used by Office of General Counsel (OGC) – Policy Division.

The Policy Division drafts advisory opinions (AOs), Notices of Proposed Rulemaking, final rules, and similar documents interpreting the federal campaign finance law, for the Commission to consider. The Policy Division also provides legal advice in response to legislative inquiries, legal reviews of all Commission publications, and training Commission staff regarding changes in the law.

This application is time sensitive and mission critical. This is because the information will be published on FEC public AO search website where OGC and Commission staff, as well as external users, can search on advisory opinions (the third-tier law after statutes and regulations). Therefore, failure of AODES can result in failure of the agency's ability to provide guidance to the public.

AODES user interface is:

<https://searchable.fec.gov/searchable/dist/root/login>

Database under AODES application contains information about each AO request the Commission has received and AO it has issued, including the name(s) of requestor(s), dates received and issued, and topic. Its main function is to provide data for the searchable AO system that is used by both internal and external users to research Commission precedent.

AODES enables authorized staff (those with password access and proper data interface utilities) with the ability to enter a specific set of data, that defines an information set about a given AO, its associated process, and/or the documents associated with the AO. The application supports the user interface and data management capabilities to support this function.

Maintenance Specifications

Attachment 1A - FEC Searchable Legal Systems

Contracting Requirements

As legislative, reporting forms, or other requirements can change, the FEC often makes unscheduled requests for data, data subsets, files from backup, changes, or enhancements to these systems. These requests are typically made on a “need it now” basis and may be critical. The quoter must demonstrate that they have the resources and the flexibility to manage and perform these types of requests without impacting the application and system maintenance or other initiatives. These requests shall be included as part of normal maintenance efforts.

Architecture

Application is located on Amazon Cloud

AODES is a three-tier application by design.

- Database tier:
Amazon Aurora PostgreSQL (with Enterprise License)
Schema(s): SMUR_APP_USER, AOSRC
- Application tier:
java program with Spring MVC, on Apache Tomcat
- Web tier:
RESTful web service, Angular, on Apache Tomcat

Application Server EC2 on Linux OS, running under load balancer.

AODES data is consumed by public searchable AO ([Search Advisory opinions | FEC](#)).

The application does not utilize file system storage.

Software

The application utilize below technologies/software:

- Java, running on Tomcat
- Spring framework
- RESTful web service, and angular
- PostgreSQL
- Jenkins, CI/CD

Development and Deployment Approach

Application may be required

- to fix bugs and errors discovered by business users or by automated tools, such as security scans,
- to add/modify features from existing features that requested by business users,
- to update the software to remain compatible with evolving environments, such as new OS versions, or third-party APIs,

Attachment 1A - FEC Searchable Legal Systems

Contracting Requirements

- to optimize the performance to improve the speed and efficiency of the application to enhance user experience.

In any above cases, Contractor should meet below requirements:

- Best practice with SDLC and Agility.
- Issue Tracking:
 - Use Jira and GitHub to track Issues.
 - In each ticket, define severity, priority, and record resolution.
- Code Quality
 - Code must adhere to coding standards (e.g., Clean Code, PEP 8) and a minimum code coverage 80% percentage for automated tests.
 - Code must pass functional tested by contractors on development environments.
- Code Deploy and pass Security Scan
 - CI/CD (currently in Jenkins) used for code compiling and pass SAST with zero critical security findings.
- Integration Test and UAT
 - Must conduct Integration test with fec public AO.
 - Must conduct User Acceptance Test.
- Change Management: any production changes must
 - have UAT certified
 - Request RFC, along with deployment items, servers, impacts, deployment procedure, backup plan.
 - RFC approved by CAB.
 - In case of emergency fix and deployment, issue and deployment can be documented later than RFC emergency approve, but document must not omit.
- Documentation:
 - Maintaining up-to-date documentation, including user manuals and technical documentation, for long-term support.
 - Link maintenance requirements to original functional specs to understand the impact of changes as Traceability.
 - Treat the maintenance specification as a living document that is updated alongside the software.
 - All documents must be accessible by FEC COR and FEC Deputy CIO of Enterprise Architecture
- Version Control:
 - Application source code, sql statements, and any other scripts must use branching strategy to manage hotfixes and new releases.

Attachment 1A - FEC Searchable Legal Systems
Contracting Requirements

Availability and Service Level Agreement (SLA)

- Availability
 - Application is running daily.
 - Patch or other maintenance should be scheduled over weekend.
- SLA
 - Critical bugs or Urgent issue must be acknowledged within 2 hours, and assign resource to fix it or find temporary workaround within 12 hours.
- **Recoverability**
 - Apart from monthly security patch over the weekend, the Maximum Tolerable Downtime (MTD) is 12 hours and Recovery Point Objectives (RPO) is 12 hours.

Compliance & Data Sovereignty

- FEC is following the principles/standards for SOC1, SOC2, SOC3, ISO 27001, ISO 27017, ISO 27018, ISO 9001, PCI, FedRAMP.
Guidance from our legal counsel: HIPAA does not apply to the FEC, since we are not a healthcare provider; however, the Rehabilitation Act and Title VII do apply to us and require federal agencies to protect the confidentiality of medical information.
- Data Classification is Public
- No end-to-end data encryption is required.

Application Security

- The protocol uses HTTPS to access the workload
- Through application, the file (from local or shared folder) is uploaded to server in blobs, blobs are converted into PDF and store in database
- User authentication is required to access AODES application

Monitoring

- **The application has monitoring solution in AWS.**
- **Automatic alerts for Application availability also sent via email.**

Backup and Restore

Production databases and application have daily snapshot and keep the snapshot for past 7 days.

Attachment 1A - FEC Searchable Legal Systems
Contracting Requirements

Environment and Shared Responsibilities

- All servers (Development, Test, Production) should be built by FEC System Administrator.
- All servers (Development, Test, Production) should be patched by FEC System Administrator.
- Test Environment Require a dedicated staging environment that mirrors production for validating fixes.
- Contractors have privileges to push code into development servers.
- Upon completion of development, test in development servers, contractors must provide detailed instructions to DBA or System Administrator for Test or Production Deployment.

Technical Support

The Channels for reporting maintenance issues is, in general, go through FEC help desk or via automated monitoring alerts, however, it should not prevent receiving reports directly from FEC internal business users.

Searchable Matters Under Review (SMUR)

Introduction

This document defines contract requirement for Federal Election Committee's Searchable Legal Systems – SMUR Application.

The requirement includes maintaining, upgrading, migrating, or re-architect/re-programing the application, based on the requests from legislation divisions, and/or from security mandates.

Application Overview

Searchable Matters Under Review, also called SMUR, used by Public Disclosure staff and Staff Director staff.

This is internal application but it is mission-critical.

Users manually pull data from LawManager as OGC and ADR cases are closed. The server comes into play when the system moves information to the public Enforcement Query System.

The purpose of SMUR is to act as an interface between LawManager data, the document repository, and the published, searchable website. Upon instigation by a User, when a case has been closed by Commission vote and redacted as needed, SMUR requests case information for that specific case based on specific unique identifying codes in LM Pro (players, calendar events) and holds that data in its database. There, the User reviews data brought in from LawManager, edits it as necessary to conform to public release practices, pulls up documents from the data repository, marries the document to the data, and publishes it into the searchable system.

SMUR interfaces with LawManager Pro and an internal share that stores documents. Within that share folders are identified by Case Type, Case Number and Case Name. Within the Case-specific folder are event-specific sub-folders (related to the Document Categories) which contains documents related to those event types. This folder/sub-folder structure is utilized as meta-data in SMUR, and helps dictate search results in public search system.

After the Commission votes to close a matter for ADR, OGC and OAR, the case file is redacted by staff as necessary. Upon the completion of the redaction, Public Disclosure staff preps the case file documents with case type, name and number and the document type written, as seen in the sub-folder titles listed above. The document then gets put through Optical Character Recognition (OCR) and is cleaned up. Then the User brings in the LawManager Pro data into SMUR, titles the documents, and publishes them. The purpose is to make available to the general public an on-line, searchable case file. Documents can be text-searched or searched based on attributes (dates, document types -- per the list above), players. OGC and ADR data comes from LM Pro; OAR data comes from an external Oracle database.

SMUR user interface is:

Attachment 1A - FEC Searchable Legal Systems
Contracting Requirements

<https://smur.fec.gov/smur>

SMUR can only be accessed by authorized staff.

Maintenance Specifications

As legislative, reporting forms, or other requirements can change, the FEC often makes unscheduled requests for data, data subsets, files from backup, changes, or enhancements to these systems. These requests are typically made on a “need it now” basis and may be critical. The vendor must demonstrate that they have the resources and the flexibility to manage and perform these types of requests without impacting the application and system maintenance or other initiatives. These requests shall be included as part of normal maintenance efforts.

Architecture

Application is located on Amazon Cloud

AODES is a three-tier application by design.

- Database tier:
Amazon Aurora PostgreSQL (with Enterprise License)
Schema(s): SMUR_APP_USER, FECMUR_APPUSER
- Application tier:
java program on Apache Tomcat
- Web tier:
JSP

Application Server EC2 on Linux OS, running under load balancer.

SMUR data is pulled from LawManager and consumed by fec public search system.

Software

The application utilizes the following technologies/software:

- Java, running on Tomcat
- Spring framework
- RESTful web service, and angular
- PostgreSQL
- Jenkins, CI/CD

Development and Deployment Approach

Application may be required

Attachment 1A - FEC Searchable Legal Systems

Contracting Requirements

- to fix bugs and errors discovered by business users or by automated tools, such as security scans,
- to add/modify features from existing features that requested by business users,
- to update the software to remain compatible with evolving environments, such as new OS versions, or third-party APIs,
- to optimize the performance to improve the speed and efficiency of the application to enhance user experience.

In any above cases, Contractor should meet below requirements:

- Best practice with SDLC and Agility.
- Issue Tracking:
 - Use Jira and GitHub to track Issues.
 - In each ticket, define severity, priority, and record resolution.
- Code Quality
 - Code must adherence to coding standards (e.g., Clean Code, PEP 8) and a minimum code coverage 80% percentage for automated tests.
 - Code must pass functional tested by contractors on development environments.
- Code Deploy and pass Security Scan
 - CI/CD (currently in Jenkins) used for code compiling and pass SAST with zero critical security findings.
- Integration Test and UAT
 - Must conduct Integration test with fec public AO.
 - Must conduct User Acceptance Test.
- Change Management: any production changes must
 - have UAT certified
 - Request RFC, along with deployment items, servers, impacts, deployment procedure, backup plan.
 - RFC approved by CAB.
 - In case of emergency fix and deployment, issue and deployment can be documented later than RFC emergency approve, but document must not omit.
- Documentation:
 - Maintaining up-to-date documentation, including user manuals and technical documentation, for long-term support.
 - Link maintenance requirements to original functional specs to understand the impact of changes as Traceability.
 - Treat the maintenance specification as a living document that is updated alongside the software.

Attachment 1A - FEC Searchable Legal Systems

Contracting Requirements

- All documents must be accessible by FEC COR and FEC Deputy CIO of Enterprise Architecture
- Version Control:
 - Application source code, sql statements, and any other scripts must use branching strategy to manage hotfixes and new releases.

Availability and Service Level Agreement (SLA)

- Availability
 - Application is running daily.
 - Patch or other maintenance should be scheduled over weekend.
- SLA
 - Critical bugs or Urgent issue must be acknowledged within 2 hours, and assign resource to fix it or find temporary workaround within 12 hours.
- **Recoverability**
 - Apart from monthly security patch over the weekend, the Maximum Tolerable Downtime (MTD) is 12 hours and Recovery Point Objectives (RPO) is 12 hours.

Compliance & Data Sovereignty

- FEC is following the principles/standards for SOC1, SOC2, SOC3, ISO 27001, ISO 27017, I SO 27018, ISO 9001, PCI, FedRAMP.
Guidance from our legal counsel: HIPAA does not apply to the FEC, since we are not a healthcare provider; however, the Rehabilitation Act and Title VII do apply to us and require federal agencies to protect the confidentiality of medical information.
- Data Classification is Public
- No end-to-end data encryption is required.

Application Security

- The protocol uses HTTPS to access the workload
- Through application, the file (from local or shared folder) is uploaded to server in blobs, blobs are converted into PDF and store in database
- User authentication is required to access AODES application

Monitoring

- **The application has monitoring solution in AWS.**
- **Automatic alerts for Application availability also sent via email.**

Attachment 1A - FEC Searchable Legal Systems
Contracting Requirements

Backup and Restore

Production databases and application have daily snapshot and keep the snapshot for past 7 days.

Environment and Shared Responsibilities

- All servers (Development, Test, Production) should be built by FEC System Administrator.
- All servers (Development, Test, Production) should be patched by FEC System Administrator.
- Test Environment Require a dedicated staging environment that mirrors production for validating fixes.
- Contractors have privileges to push code into development servers.
- Upon completion of development, test in development servers, contractors must provide detailed instructions to DBA or System Administrator for Test or Production Deployment.

Technical Support

The Channels for reporting maintenance issues is, in general, go through FEC help desk or via automated monitoring alerts, however, it should not prevent receiving reports directly from FEC internal business users.